
GenAI-Assisted Document Redaction Governance

A Governance Framework for Safe Adoption

Submitted by

Andrea Gennari

Business and Project Management

June 9, 2026

ABSTRACT

This paper proposes a governance framework for the safe adoption of Generative AI-assisted document redaction tools. The central research question is: how can organizations adopt GenAI-assisted redaction through governance, human-in-the-loop controls, audit logging and risk management? The framework is organized in four pillars anchored to GDPR, the NIST AI Risk Management Framework and ISO/IEC 42001, and is illustrated against the Post Office Horizon data breach case.

Contents

1	Framing and Foundations	4
1.1	Framework Overview	4
1.2	Defining “Safe Adoption”	4
1.3	Regulatory and Standards Baseline	5
1.4	Framework Architecture	6
2	Governance (Pillar I)	7
2.1	Operating Model and Oversight	7
2.2	GenAI-Assisted Redaction Policy	8
2.3	Decision Rights and Approval Gates	8
2.4	RACI Matrix	9
3	Human-in-the-Loop Controls (Pillar II)	9
3.1	Document Classification and Risk Scoring	9
3.2	Risk-Tier to Control Matrix	10
3.3	Review and Escalation Workflow	10
3.4	Reviewer Guidance and Automation Bias	11
4	Audit Logging and Accountability (Pillar III)	11
4.1	Purpose and Principles	12
4.2	Audit Log Schema	12
4.3	Demonstrable Compliance	12
4.4	Audit Review Process	13
5	Risk Management (Pillar IV)	13
5.1	Risk Management Approach	13
5.2	Risk Register	14
5.3	Qualitative and Quantitative Analysis	14
5.4	Risk Responses and Residual Risk	15
6	Adoption, Measurement and Business Case	15
6.1	Adoption Roadmap	16
6.2	KPIs and Control Effectiveness	16
6.3	Maturity Model	17
6.4	Business Case	17
7	Synthesis: Answering the Guiding Question	18
7.1	How the Framework Achieves Safe Adoption	18
7.2	Limitations and Assumptions	19
8	Case Analysis: Root Causes and Governance Gaps	21
9	Applying the Framework to the Case	22
9.1	Governance Controls (Pillar I)	22
9.2	Human-in-the-Loop Controls (Pillar II)	22
9.3	Audit Logging (Pillar III)	23
9.4	Risk Management (Pillar IV)	23

10 Counterfactual Analysis	23
11 Synthesis: Lessons from the Case	25
12 Proof of Concept: Validating the Controls	26

Part I

A Governance Framework for Safe Adoption

Guiding question for Part I. How can organizations adopt GenAI-assisted document redaction safely, through governance, human-in-the-loop controls, audit logging and risk management?

1 Framing and Foundations

1.1 Framework Overview

Organizations that publish documents externally need a controlled, auditable process to identify and redact sensitive content before release. GenAI can support this, but adopting it without governance adds new risks: over-reliance on automation, lost accountability, and data leakage.

This paper proposes a **governance framework** for that path, in four pillars, each addressing a distinct failure mode: Governance, Human-in-the-Loop Controls, Audit Logging, and Risk Management. Table 1 shows the structure.

Section	Content
§1: Foundations	Criteria for safe adoption and regulatory baseline
§2: Pillar I	Governance, policy and accountability structure
§3: Pillar II	Human-in-the-loop controls and document risk classification
§4: Pillar III	Audit logging and demonstrable compliance
§5: Pillar IV	Risk management process and register
§6	Adoption roadmap, KPIs and business case

Table 1: Structure of the paper.

It is designed in full, then deployed through a limited pilot before scaling: predictive design, iterative rollout, a hybrid lifecycle [1].

1.2 Defining “Safe Adoption”

The framework must be verifiable. Five criteria define safe adoption; the framework is designed to satisfy all five at once.

FIVE CRITERIA FOR SAFE ADOPTION

1. **No unauthorized disclosure.** No personal or confidential data leaves without passing documented review and approval. (The Post Office Horizon incident is the motivating failure.)

2. **Regulatory compliance.** Satisfies GDPR Art. 25 (protection by design) and Art. 32 (appropriate measures), and the ICO expectation of a documented pre-publication control.
3. **Accountability and auditability.** Every document yields a record of what was done, by whom, and when, demonstrable to a regulator or court (GDPR Art. 5(2)).
4. **Preserved human oversight.** No high-risk document is published without explicit human approval. GenAI *supports*, it does not *replace*, the reviewer, who is the final gate.
5. **Sustainable adoption.** The framework is embedded: staff trained, process followed, KPIs met in the pilot. A correct framework that is bypassed reduces no risk.

Each criterion has a failure condition that triggers escalation, the inverse of the criterion: any unredacted content published; any document processed outside the GDPR Art. 25/32 controls; any incomplete audit record; any high-risk release without recorded approval; KPI targets missed beyond tolerance or the process systematically bypassed. Each criterion is SMART: specific, measurable, attainable in the pilot, relevant, time-bound [1].

1.3 Regulatory and Standards Baseline

Three layers constrain any GenAI redaction tool: EU data-protection law, UK supervisory expectations, and international management-systems standards. Together they set the non-negotiable floor.

GDPR: Key Articles [2]

Art. 25 (by design and by default): protection must be built into the system *before* processing, not retrofitted. Here: the review gate is part of the default publication path, not a skippable add-on.

Art. 32 (security of processing): “appropriate technical and organisational measures.” Technical = GenAI detection plus mandatory human review; organisational = the policy, training, and audit log.

Art. 5(2) (accountability): the controller must *demonstrate* compliance. This drives Pillar III: without a tamper-evident record of each decision, the organization cannot prove to the ICO or a court that the controls operated.

ICO Expectations

The ICO’s 2025 reprimand of Post Office Limited held that publishing personal data without a documented pre-publication control breaches Art. 5(1)(f) and Art. 32 [6]. Its corrective requirement, a documented and auditable review process, is the origin of Pillars II and III, and it sets the bar: not just having a process, but proving it ran for every document.

NIST AI RMF (1.0)

The NIST AI RMF [3] organises AI risk around four functions: **GOVERN** (policy, accountability, risk culture), **MAP** (context and potential harms), **MEASURE** (metrics and testing), **MANAGE** (response and monitoring). Pillar I operationalises GOVERN; Pillar IV covers MAP, MEASURE and MANAGE.

ISO/IEC standards

42001:2023 [4] (AI management): pre-deployment risk assessment (Cl. 6), documented human oversight (A.6), data-subject impact evaluation (A.5). **27001:2022** [5] (information security): information classification (A.5.12), data masking (A.8.11), logging (A.8.15). The pillar that meets each clause is in Table 2.

Requirement Mapping

Table 2 maps each requirement to its source and pillar; every row ties back to a safe-adoption criterion (Section 1.2).

Requirement	Source	Addressed in
Data protection by design	GDPR Art. 25	Pillar I (policy mandate) + Pillar II (default review gate)
Appropriate security measures	GDPR Art. 32	Pillar I + II + III
Demonstrable accountability	GDPR Art. 5(2)	Pillar III (immutable audit log)
Documented pre-publication control	ICO reprimand 2025	Pillar II (HITL review gate)
AI governance and risk culture	NIST AI RMF GOVERN	Pillar I (governance structure, RACI)
AI risk identification	NIST AI RMF MAP	Pillar IV (risk register)
AI risk measurement	NIST AI RMF MEASURE	Pillar IV (performance metrics and KPIs)
AI risk treatment	NIST AI RMF MANAGE	Pillar IV (response strategies)
AI human oversight	ISO/IEC 42001 A.6	Pillar II (mandatory human approval)
AI impact assessment	ISO/IEC 42001 Cl. 6	Pillar IV (pre-deployment risk assessment)
Information classification	ISO/IEC 27001 A.5.12	Pillar II (document risk tiers)
Audit evidence	ISO/IEC 27001 A.8.15	Pillar III (audit log)

Table 2: Regulatory and standards requirements mapped to framework pillars.

1.4 Framework Architecture

The framework is a **governance spine** (Pillar I) giving authority to three operational pillars, all feeding a hybrid adoption lifecycle. One design principle governs everything that follows:

ARCHITECTURAL PRINCIPLE

AI suggests, humans approve, the organization remains accountable. The tool is a detection assistant, not a decision authority: every publication decision is owned by a named human and recorded in the log, and the policy, not the tool’s confidence score, sets when approval is mandatory.

The Governance Spine

Pillar I is load-bearing: the policy mandate, the accountability hierarchy, and the RACI matrix that authorize the other three pillars, much as a project charter formally authorizes a project and names its sponsor [1] (detailed in Section 2).

The Three Operational Pillars

- **Pillar II (Human-in-the-Loop)** classifies every document into risk tiers and routes it through the matching review gate (Section 3).
- **Pillar III (Audit Logging)** records every action in an immutable, queryable log kept as regulatory evidence (Section 4).
- **Pillar IV (Risk Management)** keeps a living risk register, tracks residual risk and triggers escalation at thresholds (Section 5).

Document Flow Through the Framework

The path runs from draft to publication in seven steps, linear for standard documents and gated by an approval step before the token issues for high and very-high ones. The full gated flow, with the control at each step, is Table 5 in Section 3.

Hybrid Adoption Lifecycle

The framework is designed predictively (all four pillars defined before the pilot) but deployed iteratively: a controlled pilot generates KPI data and calibrates the risk-tier thresholds and review workloads before full rollout. This hybrid sequencing (Section 1) cuts adoption risk without losing coherence [1].

2 Governance (Pillar I)

Pillar I is the governance spine (Section 1.4): it gives the other three pillars their authority through four artefacts: an operating model, a redaction policy, decision rights, and a RACI matrix. Without it the audit log is optional, the review gate is skippable, and the risk register has no owner.

2.1 Operating Model and Oversight

The framework is owned end to end by the **Data Protection Officer (DPO)**, who chairs a **Redaction Governance Board**: the oversight forum that approves the policy, sets the Pillar II risk thresholds, reviews KPI and audit data (Section 4), and authorizes exceptions. Five roles staff the workflow:

GOVERNANCE ROLES
• Document Owner: submits the document, runs the GenAI scan, performs first-line review, and publishes against the approval token. • Legal: advises on litigation, contractual and disclosure sensitivity; recommends on high-risk release. • DPO / Privacy: accountable owner of the framework; chairs the Board; holds classification and high-risk approval authority; attests to audit-log integrity.

- **IT Security:** owns the GenAI pipeline, the vendor assessment, access controls and the log infrastructure.
- **Manager:** holds operational accountability for the routine flow; provides resources and owns the KPIs.

These parties differ in power and interest, so the framework engages them differently [1]:

- **DPO, Legal** (high power, high interest): *manage closely*; on the Board, with approval rights.
- **IT Security** (high power, lower interest): *keep satisfied*; owns the controls, consulted per document.
- **Document owners** (lower power, high interest): *keep informed* and trained.
- **Senior management** (high power): *keep satisfied* via the Board’s reporting line.

Communication splits the same way: approval decisions are *pull* (recorded, retrieved on demand); policy changes and incidents are *push* to every owner [1].

2.2 GenAI-Assisted Redaction Policy

The policy is the artefact GDPR Art. 25 demands: it embeds data protection into the process *by default*, rather than leaving it to individual diligence under time pressure.

REDACTION POLICY AT A GLANCE

- **Purpose:** ensure no document is shared or published externally without a documented, risk-proportionate redaction review.
- **Scope:** every document leaving the organization to a named external party or the public, and all staff who publish.
- **Core principle:** AI suggests, humans approve, the organization remains accountable (Section 1.4).
- **Prohibited uses:** no automatic publication at any tier; no pasting of documents into consumer GenAI tools outside the approved pipeline; no disabling of the audit log.
- **Vendor & data handling:** a Data Processing Agreement (GDPR Art. 28), a contractual no-training clause, EU or approved data residency, and encryption in transit and at rest.

The vendor rules close a risk nothing else can: sending text to an external model is itself a disclosure. They are the control for the “data exposure to external AI vendor” risk (Section 5).

2.3 Decision Rights and Approval Gates

Decision rights answer one question (*who may authorize external release?*); the answer rises with the risk tier (Section 3). No tier permits automatic release: a human must record approval before a document advances. The tier-by-tier mapping of release authority and gate rule is consolidated in Table 4 (Section 3).

A **gate** is a hard stop: no publication until the named authority records approval in the log (Pillar III). The very-high tier adds *dual control* so no single person can release the most sensitive material. These gates operationalize the “preserved human oversight” criterion (Section 1.2).

2.4 RACI Matrix

Every activity has exactly one **Accountable** and at least one **Responsible** role, with Consulted and Informed named alongside [1]. Operational steps answer to the Manager; privacy-critical control points answer to the DPO.

Activity	Doc Owner	Legal	DPO	IT Sec.	Manager
Intake & version check	R	I	I	C	A
GenAI sensitive-data scan	R	I	C	A	I
Risk-tier classification	R	C	A	C	I
Redaction proposal review	R	C	C	I	A
High-risk release approval	I	R	A	C	C
Final publication	R	I	I	C	A
Audit review	I	C	A	R	I

Table 3: RACI matrix for the redaction governance workflow.

Legend: R = Responsible A = Accountable C = Consulted I = Informed

Two assignments carry the weight. **High-risk approval:** Accountable to the DPO, Responsible to Legal, so it is single-owned yet never decided without an independent recommendation. **Audit review:** Responsible to IT Security (who runs the log), Accountable to the DPO (who attests to it), preserving separation of duties. Every Accountable cell is a Board member.

3 Human-in-the-Loop Controls (Pillar II)

Pillar II turns “AI suggests, humans approve” into procedure: it classifies every document into a risk tier, binds each tier to a level of human control, and routes it through gated review and escalation. Human attention is spent in proportion to risk.

3.1 Document Classification and Risk Scoring

Classification is the first control and runs on *every* document. Three factors are scored; their product sets the tier.

$$\text{RISK SCORE} = \text{SENSITIVITY} \times \text{EXPOSURE} \times \text{AUDIENCE}$$

- **Sensitivity:** the data categories present: 1 = routine business; 2 = personal data; 3 = special-category, financial or litigation data.
- **Exposure:** the number of data subjects affected: 1 = a single subject; 2 = a small group (2–99); 3 = 100 or more.
- **Audience:** the reach on release: 1 = internal; 2 = a named external party; 3 = the public web.

The score (1 to 27) maps to the three tiers of Section 1.4: **standard** (≤ 4), **high** (6 to 12), **very high** (≥ 18) — the score-and-threshold logic the course applies in its Probability and Impact Matrix [1]. Override: any *public* document (Audience = 3) is floored at **high**, since public release is irreversible. The Post Office document scored the maximum ($3 \times 3 \times 3 = 27$); Part II shows the framework would have flagged it very high.

3.2 Risk-Tier to Control Matrix

The tier fixes the level of human control. Across every tier the GenAI tool only *proposes*; it never publishes. What rises with risk is the seniority and number of humans who must sign off.

Tier	GenAI role	Mandatory human control	Release authority	Gate rule
Standard	Proposes; flags candidates	Owner reviews every proposal and attests completeness	Document owner	Owner attests review complete; token issued on attestation
High	Proposes redactions	Independent reviewer (not the author) plus compliance check	DPO, on Legal's recommendation	No release until DPO approval recorded; author cannot self-approve
Very high	Proposes redactions	Independent review plus dual approval; no single-person release	DPO + senior management	Two recorded approvals; no single person can release

Table 4: Tier to GenAI role, human control, release authority and gate rule. No tier allows automatic release.

3.3 Review and Escalation Workflow

Table 5 sets out the seven-step flow with, at each step, the control gate (what must hold before advancing) and the escalation branch.

#	Actor (lane)	Action	Gate / escalation
1	Document owner	Submit draft and intended audience	(none)
2	System	Score and classify the tier	Public audience floors the tier at high
3	GenAI tool	Propose redactions with confidence scores	Low-confidence items flagged for mandatory attention
4	Reviewer	Confirm or override each proposal; attest completeness	High / very high require an <i>independent</i> reviewer
5	Approver	Approve the redacted version	High: DPO gate. Very high: DPO + senior (dual). A disagreement between reviewer and approver escalates to the Board
6	Audit log	Lock the record; issue approval token	No token without a complete record
7	Document owner	Publish against the token	Publication blocked without a valid token

Table 5: Gated review-and-escalation workflow (swimlane by actor).

3.4 Reviewer Guidance and Automation Bias

The weak point of any human-in-the-loop design is *automation bias*: if reviewers rubber-stamp the tool, the gate is theatre and the over-reliance risk (Section 5) materializes. Four choices counter it:

- **Show the original, not just the result.** The reviewer sees the source document beside the proposals, so a *missing* redaction is visible rather than hidden in clean-looking output — the course’s survivorship-bias lesson [1]: the decisive evidence is what is *not* shown, so look hardest where the tool reports nothing.
- **Make confirmation an act, not a default.** The reviewer positively confirms each proposed redaction, and a “no sensitive data” outcome requires an explicit attestation: a recorded decision, never a silent pass.
- **Measure catch rate.** Blind quality samples (documents seeded with known sensitive items) test whether reviewers catch what the tool misses; the catch rate is a KPI (Section 6).
- **Gate on competence.** Only trained reviewers are provisioned, and high-risk review requires additional training, the control for the “lack of staff training” risk.

In PM terms, classification is Probability-and-Impact-Matrix prioritization and escalation is structured decision-making [1].

4 Audit Logging and Accountability (Pillar III)

Pillar III turns the workflow into evidence. GDPR Art. 5(2) requires the organization to *demonstrate* compliance, not just achieve it, and the ICO’s reprimand of Post Office

Limited turned on the absence of a documented pre-publication process [6]. The log is the artefact that proves, for any document, that the Art. 32 controls operated.

4.1 Purpose and Principles

THREE PROPERTIES OF THE LOG

Complete: every document that enters the workflow produces a record; no record, no publication token.

Immutable: entries are append-only and tamper-evident (hash-chained), so a record cannot be edited after the fact to look compliant.

Traceable: every entry binds an action to an identified actor and a timestamp, so the whole decision chain can be reconstructed.

Completeness is enforced by the Pillar II token gate; immutability earns a regulator's trust; traceability answers "who decided this, and when?"

4.2 Audit Log Schema

Four field groups, plus the controls that protect the log itself:

AUDIT LOG SCHEMA

- **Document identity:** document ID; type; version hash; owner; intended audience; classification tier.
- **Detection:** GenAI model and version; sensitive-data categories detected; per-item confidence scores; scan timestamp.
- **Decision:** reviewer identity; each proposal confirmed or overridden; changes made; completeness attestation; escalation flag.
- **Disposition:** approver identity; approval or rejection; approval timestamp; approval token ID; publication status.

Controls on the log: append-only (no edit or delete for any role); read access restricted to DPO and IT Security; access to the log is itself logged; retention aligned to the limitation period for related claims, then deletion (GDPR Art. 5(1)(e), storage limitation).

Recording the model version and per-item confidence lets an investigation separate a tool failure (item never flagged) from a reviewer failure (flagged but dismissed).

4.3 Demonstrable Compliance

The test of the log is whether it answers a regulator: to "show that document X was handled correctly," one query returns who scanned it, what was detected, who reviewed and changed it, who approved it, and when. Table 6 maps log elements to requirements.

Log element	Requirement satisfied
Complete per-document record	GDPR Art. 5(2) accountability; ICO documented-process expectation
Reviewer and approver identity + timestamp	Art. 32 (which control operated, and by whom); preserved-oversight criterion
Detected categories and redaction changes	Art. 32 (evidence the measure worked); “no unauthorized disclosure” criterion
Append-only, tamper-evident storage	Evidential integrity for the ICO or a court
Retention limit and restricted access	Art. 5(1)(e) storage limitation; Art. 32 confidentiality

Table 6: Audit-log elements mapped to the requirements they evidence.

4.4 Audit Review Process

The log is reviewed, not just retained: monthly, the DPO reviews a sample plus *every* very-high record; quarterly, the Board reviews KPIs and exceptions. Any anomaly (missing approver, bypassed gate, incomplete record, KPI breach) is logged as an incident and escalated, closing the loop with Pillar IV. In PM terms, the log is project documentation and configuration management: the controlled record that makes the process auditable and turns “a control exists” into a verifiable baseline [1].

5 Risk Management (Pillar IV)

Pillar IV manages the risk of the tool itself. Automation removes some risk (human inconsistency, volume misses) but adds new, *secondary* risks [1]: automation bias, vendor exposure, false confidence. The PMI process identifies, scores, treats, and monitors them [1].

5.1 Risk Management Approach

The PMI process has six steps, and each already has a home in the framework rather than living as a separate exercise:

- **Plan:** the redaction policy and this pillar’s method (Pillar I).
- **Identify:** the risk register below.
- **Qualitative analysis:** the Probability and Impact Matrix [1].
- **Quantitative analysis:** EMV and a decision tree for the costliest risks [1].
- **Plan responses:** one of avoid / transfer / mitigate / accept per risk, mapped to Pillars I, II and III.
- **Monitor & control:** the audit review (Pillar III) and KPIs (Section 6), with defined triggers.

5.2 Risk Register

Each risk is written in the course’s *cause–risk–effect* formulation [1]; the category column is the project’s Risk Breakdown Structure (RBS), so responses target causes. P and I are *inherent* ratings (pre-control); residuals are in Table 9.

ID	Category (RBS)	Cause	Risk (uncertain event)	Effect	P	I
R1	Detection	Model limits; novel data formats	Sensitive data not detected (false negative)	Unredacted PII published	M	H
R2	Process	No version control; manual handling	Wrong document version published	Outdated, uncontrolled disclosure	M	H
R3	Human factor	Reviewer defers to the tool	Over-reliance on AI (automation bias)	Tool misses pass unchecked	M	H
R4	Compliance	No persistent record of decisions	Cannot demonstrate compliance	Regulatory finding; no defence	M	H
R5	Vendor / data	Text sent off-premise for inference	Document text exposed to external vendor	Secondary data breach	M	H
R6	Quality	Conservative model tuning	Excess false positives	Overprocessing; eroded trust	H	M
R7	Organizational	Rushed rollout	Staff untrained; process bypassed	Controls not applied	M	M
R8	Governance	No defined decision rights	Unclear accountability for release	No owner, no gate	M	H

Table 7: Risk register in cause–risk–effect form (inherent probability P and impact I, before controls).

5.3 Qualitative and Quantitative Analysis

The **Probability and Impact Matrix** [1] shows the profile (Table 8). The cluster in the medium-probability / high-impact cell justifies a control-heavy framework: these risks are neither rare nor mild.

Probability ↓	Impact →		
	Low	Medium	High
High		R6	R1, R2, R3, R4, R5, R8
Medium		R7	
Low			

Table 8: Probability and Impact Matrix of the inherent risk register.

The costliest risks are weighed by **expected monetary value** ($EMV = \text{probability} \times \text{impact}$, summed over the register) and a decision tree whose branches are compared on EMV [1] — the very tools the course applies to regulatory, compliance and litigation risk, which is precisely this domain. A control pays off when the expected loss it removes exceeds its cost. Two caveats: EMV is an average, and an average hides the tail (the flaw of

averages), so moving *from average values to distributions* by Monte Carlo simulation is what would reveal it [1]; this is why the very-high tier uses dual control rather than a cost-benefit test. These figures are illustrative, the case-calibrated EMV being deferred to the Part II counterfactual (Section 10).

5.4 Risk Responses and Residual Risk

Each risk takes one of the four PMI strategies (avoid, transfer, mitigate, accept), delivered by a control in another pillar [1]: the framework is the response plan for its own register.

ID	Strategy	Response (control → pillar)	Residual
R1	Mitigate	Mandatory review of all proposals; independent review for high risk; catch-rate KPI (→ II)	Low/Med
R2	Mitigate	Version hash and token-gated publication (→ II/III)	Low
R3	Mitigate	Confirm-each-item review, original shown, blind samples, training (→ II)	Low/Med
R4	Mitigate	Immutable, complete audit log (→ III)	Low
R5	Transfer + mitigate	DPA and no-training clause shift liability; EU residency limits exposure (→ I)	Low/Med
R6	Accept (reduce)	Reviewer adjusts proposals; thresholds tuned in the pilot; residual false positives accepted as the cost of safety (→ II)	Med
R7	Avoid + mitigate	No provisioning without training; gated rollout (→ I)	Low
R8	Mitigate	RACI, decision rights and approval gates (→ I)	Low

Table 9: Risk responses mapped to controls, with residual risk.

All four strategies appear: most risks are *mitigated*; vendor liability is partly *transferred* by contract (R5); untrained-staff exposure is *avoided* (R7); irreducible false positives are *accepted* (R6) — deliberately, to avoid *overmitigation*, since over-tuning the detector only multiplies false positives and overprocessing [1]. Residual risk is monitored via the audit review and KPIs, with **triggers** (catch rate below target, or any released-without-approval event) escalating to the Board, backed by a *contingency reserve* for the known risks in the register and a *management reserve*, owned by senior management, for the unknown-unknowns [1]. The claim is not zero risk but controlled risk: every inherent risk is moved out of the red cell of the Probability and Impact Matrix (Table 8) and kept there.

6 Adoption, Measurement and Business Case

Criterion 5 (Section 1.2) makes embedded adoption part of safe adoption, not an afterthought. This section makes it operational: a phased roadmap with go/no-go gates, the KPIs that prove the controls run, a maturity model to position progress, and the business case that justifies the spend.

6.1 Adoption Roadmap

Rollout follows the hybrid lifecycle of Section 1.4 [1]: four phases, each closed by a **gate**, where the next phase does not start until the exit criterion is met.

Phase	Key activities	Deliverable	Gate (go/no-go)
1. Assess	Map document flows; baseline current risk; vendor and DPA due diligence (Pillar I)	Risk baseline; approved vendor	DPA signed; Board mandate
2. Design	Configure tiers and thresholds; build the log; write policy and RACI; train reviewers	Configured pipeline; trained reviewers	Policy approved; reviewers certified
3. Pilot	Run a bounded document set live; collect KPI data; calibrate thresholds	KPI dataset; tuned thresholds	KPI targets met; zero leakage
4. Scale	Extend to all publishing units; embed audit review and reporting	Org-wide rollout; steady-state KPIs	Adoption > 70%; sustained KPIs

Table 10: Phased adoption roadmap with exit gates.

Work breakdown and schedule.

The Design phase decomposes, via the WBS, into four work packages [1]: (WP1) vendor contracting and DPA; (WP2) pipeline integration and log infrastructure; (WP3) policy, RACI and decision rights; (WP4) reviewer training and certification. WP1 is the longest-lead item and gates WP2, so the **critical path** runs WP1 → WP2 → Pilot. Durations on the uncertain packages (integration, training) use the course’s three-point PERT estimate on a beta distribution, $t_e = (o + 4m + p)/6$ [1], to size a realistic schedule and a time buffer ahead of the pilot gate.

6.2 KPIs and Control Effectiveness

KPIs answer one question: do the controls actually operate? They split into **leading** indicators — the course’s *key control indicators*, tracking whether the critical controls run [1] — and **lagging** indicators, the *key risk indicators* that track outcomes against the organization’s risk appetite [1]. Each ties to a safe-adoption criterion and feeds the Pillar IV triggers (Section 5).

KPI	Type	Formula	Target
Pre-publication scan rate	Lead	Documents scanned / documents published	100%
Audit completeness	Lead	Documents with a complete log / total processed	100%
High-risk approval rate	Lead	High-risk docs with recorded DPO approval / total high-risk	100%
Reviewer catch rate	Lead	Seeded items caught / seeded items planted	$\geq 95\%$
Average review time	Lead	Mean time from upload to approval	$< 24\text{h}$
User adoption rate	Lead	Active users / target users	$> 70\%$
False-negative rate	Lag	Sensitive items missed / total sensitive items	$< 5\%$ pilot
Wrong-version incidents	Lag	Wrong document versions published	0
Data-leakage incidents	Lag	Confirmed leakage events	0

Table 11: KPIs, split into leading (process) and lagging (outcome) indicators.

Control effectiveness is read from the pairing: a leading KPI on target while a lagging KPI breaches signals a control gap, not a staffing one. The catch rate (blind seeded samples, Section 3) is the direct test of automation bias; a breach on any lagging indicator is a trigger that escalates to the Board with the residual risk it exposes (Section 5).

6.3 Maturity Model

A five-level model positions where an organization sits and what the pilot must move. The framework targets Level 4 by end of pilot, Level 5 at steady state.

L	Stage	Characteristic
1	Ad hoc	Redaction is manual and discretionary; no policy, no record (the Post Office baseline)
2	Defined	Policy, tiers and RACI exist on paper; application is inconsistent
3	Managed	HITL gates and audit log operate for every document
4	Measured	KPIs are collected and drive threshold and workload calibration
5	Optimized	Metrics feed continuous improvement; controls self-correct on triggers

Table 12: Redaction-governance maturity model.

6.4 Business Case

This is the project **business case** [1], reframed: **risk-driven, not cost-saving driven**. Adopting the framework *changes* the organization rather than running it [1], so it is a

project to be justified, not an operating cost to be minimized: direct annual cost may rise, while the value is the expected loss avoided, so the justification is a risk-adjusted return on investment rather than a cheaper-processing saving. Assume 200 externally published documents per year.

Item	Manual	GenAI-assisted
Average review time	45 min	20 min
Total review hours (at EUR 35/h)	150	66.7
Human review cost	EUR 5,250	EUR 2,334
Software / API cost	EUR 0	EUR 10,000
Total annual cost	EUR 5,250	EUR 12,334

Table 13: Illustrative direct-cost comparison (pilot scale).

The framework costs about EUR 7,000 more per year in direct terms. The return is on the risk side: a single publication of unredacted personal data exposes regulatory fines, compensation and reputational loss far above this figure. Treating the framework as a risk-reduction investment, it pays off when the expected loss it removes (probability of a breach $\times$ its impact) exceeds the incremental cost: the EMV logic of Section 5. The case-calibrated figures, anchored to the Post Office impact, are computed in the Part II counterfactual (Section 10).

BOTTOM LINE

The direct cost is the premium; the avoided expected loss is the cover. The framework is justified not by cheaper review but by the breach it prevents.

7 Synthesis: Answering the Guiding Question

7.1 How the Framework Achieves Safe Adoption

Part I asked how an organization can adopt GenAI-assisted redaction safely (Section 1). The answer is structural: the four pillars are engineered so that the five criteria of Section 1.2 hold *together*, not one at a time. Table 14 traces each criterion to the mechanism that delivers it and the evidence that shows it operating.

Criterion	How the framework satisfies it	Evidence
No unauthorized disclosure	Mandatory review gate on every tier; no automatic release at any tier	§3, Tab. 4
Regulatory compliance (GDPR Art. 25/32)	Policy by default plus technical and organisational measures mapped to each clause	§1.3, Tab. 2
Accountability and auditability	Complete, immutable, traceable per-document log	§4, Tab. 6
Preserved human oversight	Named approver per tier; dual control at very high; no single-person release	§2, Tab. 4
Sustainable adoption	Gated roadmap, leading and lagging KPIs, and a maturity target	§6, Tab. 10, 11

Table 14: The five safe-adoption criteria mapped to the mechanism that delivers each and the evidence it operated.

No criterion depends on goodwill or on a single control: each is carried by a named pillar and evidenced in the log, and the failure condition of each (Section 1.2) is itself a monitored trigger (Section 5). The framework is therefore a coherent path to safe adoption, not a checklist, and that is the answer to the guiding question.

7.2 Limitations and Assumptions

The framework reduces risk; it does not eliminate it, and it rests on assumptions that must hold for the controls to work.

Assumptions.

- **The GenAI tool is a competent first pass.** The design is tool-agnostic, but a weak detector raises reviewer workload rather than breaking the controls, and a strong one lowers it.
- **Reviewers engage genuinely.** Automation bias is mitigated (Section 3), not abolished; the controls assume the trained reviewer actually looks.
- **The vendor honours the agreement.** The Data Processing Agreement and no-training clause make R5 a transferred risk, reduced by contract, not removed.
- **Governance is resourced.** The Board, training and audit review carry a standing cost; criterion 5 fails if it is not paid.

Limits.

- **Not zero risk.** Residual false negatives remain (Table 9); the claim is controlled risk, not eliminated risk.
- **Designed, not yet validated.** The KPI targets are set, not demonstrated, and the cost figures are illustrative; a pilot is what would confirm them.
- **Bounded scope.** This is a single-organization publication workflow, not a full software architecture, a live deployment, or legal advice.

These are the boundary of the claim, not loose ends: the framework is an internally coherent, standards-anchored design whose effectiveness is argued here and would be

measured in a pilot.

Part II

The Post Office Horizon Case

***Guiding question for Part II.** How could a GenAI-assisted governance framework have reduced the privacy and data leakage risks in the Post Office Horizon document publication case?*

8 Case Analysis: Root Causes and Governance Gaps

In 2024, Post Office Limited published an unredacted legal settlement document on its public website. The file carried the names and addresses of hundreds of claimants in the Horizon group litigation, and it stayed publicly reachable until it was noticed and removed [7]. In 2025 the Information Commissioner’s Office issued a reprimand, finding that the organization had not put in place appropriate technical and organisational measures, the standard required by GDPR Art. 32 [6].

Read as a project-management failure rather than a typing slip, the breach is instructive: a single routine action (uploading a file) produced irreversible public disclosure because nothing stood between that action and the public web. The proximate cause was a wrong-file upload; the root cause was the absence of a governance layer. A short root-cause drill makes the gap explicit.

ROOT-CAUSE DRILL (FIVE WHYS)

1. **Why was personal data exposed?** An unredacted version of the document was published.
2. **Why was an unredacted version published?** The wrong file was uploaded and nothing checked it before release.
3. **Why did nothing check it?** There was no mandatory pre-publication redaction review.
4. **Why was there no review?** Publication carried no sensitivity classification and no approval gate.
5. **Why was there no gate?** No role was accountable for redaction governance.

Root cause: no governance layer (classification, mandatory review, approval gate, audit) sat between an individual’s action and irreversible public disclosure.

Each “why” is a control the framework supplies. Table 15 maps the observed failures to the governance gap behind each one and to the pillar that closes it. The case is, in effect, a live realization of four risks already in the Part I register (Table 7): R2 (wrong version), R4 (cannot demonstrate compliance), R8 (unclear accountability), and an uncontrolled R1 (sensitive data never detected, because it was never scanned).

What happened	Governance gap (root cause)	Missing control
Unredacted version published	No mandatory pre-publication redaction review	Pillar II review gate
Wrong file version uploaded	No version control or pre-publication check	Pillar II classification; Pillar III token
Top-sensitivity document treated as routine	No document classification or risk scoring	Pillar II risk tiers
Released by one person, no sign-off	No decision rights or approval gate for high-risk release	Pillar I decision rights; Pillar II gate
Could not show a controlled process	No audit trail of who did what, and when	Pillar III audit log
No owner answerable for the outcome	Accountability never assigned	Pillar I RACI and governance spine

Table 15: Post Office Horizon document breach: observed failures, root causes and the missing controls.

The pattern is consistent: every gap is organizational, not technical. No new software was required to prevent this breach, only a governed process. That is the lesson the framework operationalizes [1].

9 Applying the Framework to the Case

This section runs the same document through the framework, pillar by pillar, and marks the point at which each control would have stopped the breach. The input is a litigation settlement holding the personal data of hundreds of claimants, intended for the public web: the highest-stakes case the framework is designed for.

9.1 Governance Controls (Pillar I)

The document falls squarely inside the redaction policy’s scope (an external, public release of personal data), so the process is not optional. Decision rights place a public release of litigation data in the very-high tier, where authority sits with the DPO plus senior management under dual control (Section 2): no single employee may release it. The RACI matrix (Table 3) names an Accountable owner for the release, so “upload” can no longer be the final act of one person. The gap behind R8 closes here: the decision acquires an owner and a gate.

9.2 Human-in-the-Loop Controls (Pillar II)

Classification is decisive. Scoring the document on the Section 3 scale gives Sensitivity 3 (litigation and special-category data) $\times$ Exposure 3 (hundreds of subjects) $\times$ Audience 3 (public web) = 27, the maximum, and the public-audience override would floor it at high even if the score were lower. That tier mandates independent review plus dual approval, with no automatic release (Table 4). Because the reviewer sees the source document beside the proposals and must positively clear it (Section 3), an unredacted file is not a clean-looking pass: the exposed names and addresses are exactly what the reviewer is required

to catch. The wrong version cannot reach the publication path, because publication is blocked without an approval token (step 7 of Table 5).

9.3 Audit Logging (Pillar III)

Every step leaves a record: who classified the document, who reviewed it, what was changed, who approved it, the version hash and the timestamps (Section 4). Publication is impossible without an approval token bound to a complete log entry, which forecloses the wrong-version upload at the technical level. Crucially, this is the precise gap the ICO penalized: instead of being unable to show a controlled process, the organization could answer the regulator with the full decision trail for the document, satisfying the accountability duty of GDPR Art. 5(2). R4 closes here.

9.4 Risk Management (Pillar IV)

The case is a materialized draw from the register (Section 5): R2, R4 and R8 occurring together, with R1 left uncontrolled. The framework’s responses target each one directly: version hash and token-gated publication (R2), the immutable log (R4), RACI and decision rights (R8), and mandatory classified review (R1). In monitoring terms, the “released-without-approval” trigger would have fired before disclosure, and the wrong-version-incident KPI (target 0, Table 11) would have flagged the event. The residual risk is a reviewer clearing a genuinely mislabelled file despite dual control: small, and itself surfaced by the audit review.

10 Counterfactual Analysis

Section 9 shows the framework would have blocked the breach qualitatively. This section asks the quantitative question a manager would: what is the expected annual loss with and without the framework, and does the difference justify the cost? It is the case-calibrated version of the expected-monetary-value sketch deferred from Sections 5 and 6 [1].

Modelling the decision.

The publication step is a **decision tree** [1] (Figure 1): a decision node with two branches, control on or control off, each leading to a chance node where a breach either occurs or does not, the branches compared on expected value. Folding the tree back needs two inputs: the annual probability of a publication-stage breach and its impact. Both are illustrative, chosen consistently with the Part I figures; what matters is the structure and the order of magnitude, not precision (Section 7).

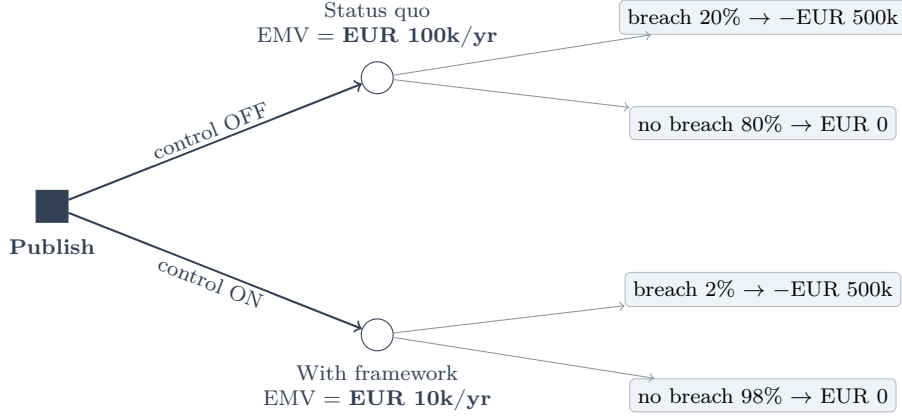


Figure 1: Decision tree for the publication step, branches compared on EMV. Expected loss avoided = EUR 90k/yr; net of the EUR 7k incremental direct cost (Table 13), net expected benefit $\approx$ EUR 83k/yr.

Impact.

A serious public disclosure of special-category data for hundreds of subjects carries regulatory exposure, remediation and notification cost, possible compensation, and reputational damage. In this case the ICO issued only a *reprimand*: it weighed a fine of up to about GBP 1.1 million but judged the breach not “egregious” under its public-sector approach [6], while the Post Office still paid compensation and identity-protection costs to those exposed. A private controller would more plausibly face the fine, so, calibrated to a generic organization, an illustrative EUR 500,000 per event is conservative against the GDPR maximum.

Probability.

For an organization publishing roughly 200 sensitive documents a year with no pre-publication gate, an annual probability of one serious slip on the order of 20% is plausible, and the Post Office outcome shows the event is far from hypothetical. The framework’s mandatory classification, dual-approval gate and token reduce this to a residual of about 2% (reviewer error despite the controls).

Scenario	Breach prob./yr	Impact	EMV (loss/yr)
Without framework (status quo)	20%	EUR 500,000	EUR 100,000
With framework	2%	EUR 500,000	EUR 10,000
Expected loss avoided			EUR 90,000
Less incremental cost (Table 13)			(EUR 7,000)
Net expected annual benefit			EUR 83,000

Table 16: Expected-monetary-value counterfactual: expected annual loss with and without the framework (illustrative figures).

On expected value, the framework returns about EUR 83,000 a year against a roughly EUR 7,000 incremental cost: a risk-adjusted payback many times over, and the deferred answer to the Part I business case (Section 6).

Why the average understates the case.

EMV is a mean, and a mean hides the tail, the flaw of averages [1]: *the devil is in the tail*. The danger is not a steady drip of EUR 100,000 a year; it is the single catastrophic disclosure, which is exactly the event that occurred. This sits in the tail the course warns about — a Black-Swan-class event [1]: rare, severe, and obvious only in hindsight (the ICO called it “entirely preventable” [6]). The course’s prescription for such events is to *narrow the window* they can pass through [1], and the mandatory gate is exactly that narrowing. A low-frequency but irreversible risk is not governed by a cost-benefit average, which is why the very-high tier uses dual control rather than an EMV test (Section 5): the framework is justified not because expected value is positive, but because the tail outcome is one the organization cannot accept. The Post Office case is that tail made real.

11 Synthesis: Lessons from the Case

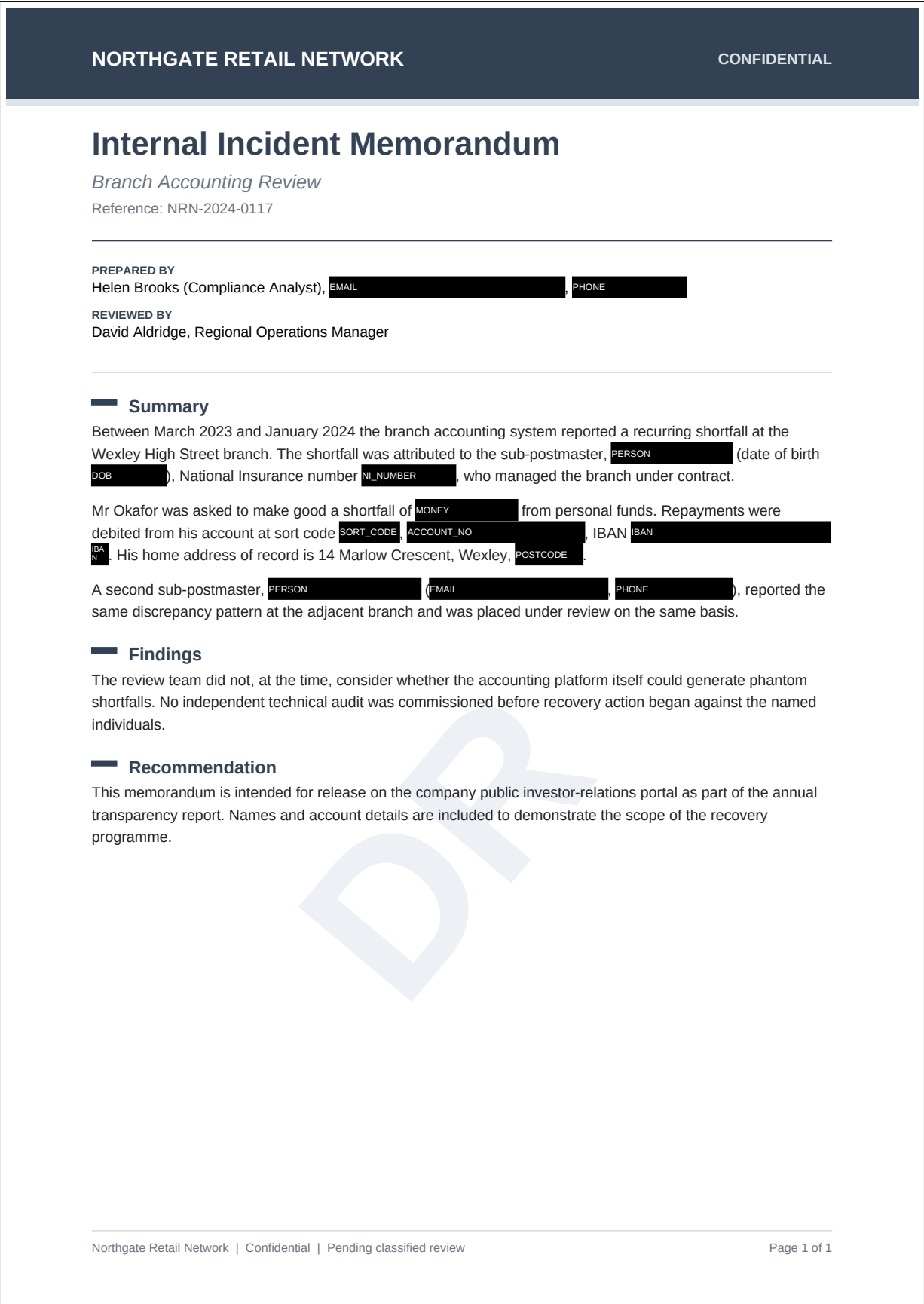
Read as a lessons-learned review [1], four lessons generalize beyond this case:

- **Redaction is a governance problem.** The failure was the absence of decision rights, a gate and a record, not the absence of a better tool (Section 8).
- **The gate matters more than the model.** Even without GenAI, a mandatory classified review with approval and logging would have prevented the breach; GenAI lowers the cost of doing this at scale, it does not replace it.
- **Accountability must be assigned before the incident.** A named Accountable owner and dual control for the top tier remove the single point of failure the case exposed.
- **Auditability is what proves the process ran.** The ICO penalized the inability to demonstrate control; an immutable log turns “we have a process” into evidence (GDPR Art. 5(2)).

12 Proof of Concept: Validating the Controls

To show the framework is operational and not only conceptual, a small proof of concept exercises the Pillar II and Pillar III pipeline end to end on a seeded sample document — the *verification-and-validation* step that moves a predictive design toward a validated deliverable before the pilot of Section 6 [1].

Run against a draft memo flagged for public release that holds the bank and identity data of two named individuals, the pipeline behaves exactly as the framework prescribes. The document is classified automatically; sensitivity, exposure and the public-web audience score it into the **very-high** tier; and it is routed to that tier’s control — **independent review plus dual approval**, with no automatic release. The audit record is written and **publication stays blocked until a human clears the gate**: no record, no token, no release. Figure 2 shows the redacted output, every detected item removed while the narrative is preserved, so the document stays useful.



Northgate Retail Network | Confidential | Pending classified review

Page 1 of 1

Figure 2: Proof-of-concept output: each detected personal or financial item is removed and replaced by a labelled bar, while the narrative (here, the absence of a technical audit before recovery) is preserved.

The proof of concept is deliberately partial in one telling way: an untitled name slips past automatic detection. That miss is the point — it makes the automation-bias argument concrete. Detection is a first pass with partial recall, so the human reviewer must catch what the tool leaves, which is why no tier permits automatic release (Section 3). The negative result is as instructive as the positive: detection is an aid to a human gate, not a replacement for it.

References

- [1] Alessio Falchi. *Project & Business Management: Course Slides*. University of Pisa, 2024.
- [2] European Union. *General Data Protection Regulation (GDPR), Articles 5, 25 and 32*.
- [3] National Institute of Standards and Technology. *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. 2023.
- [4] International Organization for Standardization. *ISO/IEC 42001:2023, Artificial Intelligence Management Systems*. 2023.
- [5] International Organization for Standardization. *ISO/IEC 27001:2022, Information Security Management Systems*. 2022.
- [6] Information Commissioner's Office. *Post Office Limited Reprimand*. 2025.
- [7] The Guardian. *Post Office accidentally leaks names and addresses of wrongfully convicted operators*. 2024.